

Trường Đại học Công nghệ-Đại học Quốc Gia Hà Nội

KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO BÀI TẬP

Môn học: Nhập môn công nghệ số và ứng dụng trí tuệ nhân tạo

**Đề tài: ĐÁNH GIÁ RỦI RO BẢO MẬT CỦA CÁC CÔNG CỤ AI HỖ TRỢ LẬP
TRÌNH ĐỐI VỚI CHẤT LƯỢNG MÃ NGUỒN**

Sinh viên thực hiện: Nguyễn Viết Thông

MSV: 25020410

Lớp: IT1

Hà Nội, Năm 2026

I. MỞ ĐẦU

1. Lý do chọn đề tài: Các công cụ AI hỗ trợ lập trình như GitHub Copilot đang ngày càng phổ biến nhờ khả năng tăng tốc quá trình phát triển phần mềm. Tuy nhiên, việc phụ thuộc vào mã do AI tạo ra có thể dẫn đến các rủi ro bảo mật nếu không được kiểm soát chặt chẽ. Vì vậy, báo cáo này nhằm đánh giá mức độ ảnh hưởng của AI coding assistants đến chất lượng và độ an toàn của mã nguồn.

2. Mục tiêu và phạm vi báo cáo: Báo cáo này hướng tới việc sử dụng Trí tuệ nhân tạo (AI) như một công cụ hỗ trợ để tổng hợp, phân tích và đối chiếu các luồng quan điểm khác nhau về độ an toàn của GitHub Copilot. Từ đó, rút ra nhận định khách quan về mức độ rủi ro và đề xuất các phương pháp phòng ngừa cho quy trình phát triển phần mềm.

3. Phương pháp thu thập tài liệu: Để đảm bảo tính khách quan và đa chiều, em đã thu thập tổng cộng 10 tài liệu chất lượng cao từ các nguồn đáng tin cậy, được chia làm hai nhóm chính:

5 bài báo khoa học thực nghiệm: Khai thác từ các thư viện học thuật uy tín như ACM và arXiv, tập trung vào việc đo lường rủi ro của Copilot bằng số liệu thực tế.

5 tài liệu/tiêu chuẩn ngành: Bao gồm tài liệu từ nhà phát triển (GitHub Copilot Trust Center), tiêu chuẩn bảo mật quốc tế (OWASP Top 10 for LLMs) và báo cáo từ các công ty bảo mật nhằm đối chiếu lý thuyết với thực tiễn ngành IT.

4. Công cụ AI và phương pháp sử dụng: Em đã sử dụng công cụ AI (Google Gemini / ChatGPT) kết hợp với kỹ thuật Prompt Engineering (Cấu trúc câu lệnh) để: Tóm tắt nhanh mục tiêu, phương pháp của các bài báo và Đối chiếu sự mâu thuẫn giữa cam kết bảo mật của hãng và kết quả nghiên cứu thực nghiệm.

5. Đánh giá độ tin cậy của tài liệu:

STT	Tài liệu	Loại nguồn	Authority	Objectivity	Currency	Relevance	Đánh giá
1	Fu et al. (2025)	Bài báo ACM	Rất cao	Rất cao	Rất mới	Trực tiếp	★ ★ ★ ★ ★
2	Chatterjee et al. (2024)	Báo cáo doanh nghiệp	Cao	Trung bình	Mới	Trực tiếp	★ ★ ★ ★
3	Majdinasab et al. (2023)	arXiv	Cao	Cao	Mới	Trực tiếp	★ ★ ★ ★
4	Res et al. (2024)	arXiv	Cao	Cao	Mới	Trực tiếp	★ ★ ★ ★
5	Nettur et al. (2025)	Survey paper	Cao	Cao	Rất mới	Trực tiếp	★ ★ ★ ★
6	GitHub Trust Center (2024)	Tài liệu hãng	Cao	Trung bình	Mới	Liên quan	★ ★ ★
7	MITRE CWE Top 25 (2025)	Tiêu chuẩn	Rất cao	Rất cao	Cập nhật	Trực tiếp	★ ★ ★ ★ ★
8	NIST CSF 2.0 (2024)	Tiêu chuẩn	Rất cao	Rất cao	Mới	Trực tiếp	★ ★ ★ ★ ★
9	OWASP Top 10 for LLMs (2024)	Tiêu chuẩn	Rất cao	Rất cao	Mới	Trực tiếp	★ ★ ★ ★ ★
10	Synopsys	Báo cáo	Cao	Cao	Mới	Liên quan	★ ★ ★ ★

STT	Tài liệu	Loại nguồn	Authority	Objectivity	Currency	Relevance	Đánh giá
	OSSRA (2024)	ngành					

II. KẾT QUẢ PHÂN TÍCH TỪ AI

Bảng tổng hợp kết quả 5 bài báo thực nghiệm:

STT	Nguồn/Tác giả	Mục tiêu nghiên cứu	Phương pháp chính	Kết quả cốt lõi
1	Fu, Y. et al. (Tập chí ACM)	Đánh giá điểm yếu bảo mật của mã do Copilot tạo ra trong các dự án thực tế.	Phân tích tĩnh (CodeQL, Bandit...) kết hợp thủ công trên 733 đoạn mã từ GitHub.	Khoảng 30% đoạn mã được phân tích chứa lỗ hổng bảo mật, rải rác trên 43 danh mục CWE khác nhau.
2	Chatterjee, S. et al. (ANZ Bank)	Đánh giá tác động thực tế của Copilot đối với kỹ thuật phần mềm trong môi trường doanh nghiệp lớn.	Thực nghiệm kiểm soát trong 6 tuần trên quy mô 1000 kỹ sư phần mềm tại ngân hàng.	Cải thiện mạnh mẽ năng suất lập trình, nhưng tạo ra "điểm mù" rủi ro nếu lập trình viên quá tin tưởng vào mã AI mà không kiểm duyệt.
3	Majdinasab, V. et al.	Đánh giá lại độc lập (Replication Study) về mức độ an toàn của mã do Copilot và CodeWhisperer tạo ra.	Thực nghiệm tạo mã bằng AI theo các kịch bản lỗ hổng và đối chiếu với nghiên cứu gốc.	Xác nhận AI vẫn tiếp tục tạo ra mã chứa các lỗ hổng bảo mật đã biết nếu không có cơ chế rào cản chặt chẽ.
4	Res, J. et al.	Tìm phương pháp cải thiện độ an toàn cho mã AI tạo ra thông qua Kỹ nghệ Prompt (Prompt-Engineering).	Đề xuất và thử nghiệm 3 phương pháp chỉnh sửa câu lệnh (Kịch bản cụ thể, Lặp lại, Mệnh đề chung).	Đưa các ràng buộc bảo mật trực tiếp vào câu lệnh (Prompt) giúp giảm thiểu đáng kể lỗ hổng bảo mật với chi phí cực thấp.
5	Nettur, S. B. et al.	Tổng hợp toàn diện vai trò của Copilot đối với năng suất, bảo mật và đề xuất quy chuẩn thực hành.	Khảo sát tài liệu học thuật (Literature survey) kết hợp báo cáo thực tiễn từ ngành công nghiệp.	AI tăng tốc độ prototyping nhưng rủi ro bảo mật và bản quyền vẫn còn; bắt buộc phải có khung tiêu chuẩn "AI có trách

PHẦN III: ĐỐI CHIẾU THỰC TIỄN VÀ PHẢN BIỆN CÁ NHÂN

1. Sự mâu thuẫn giữa Lý thuyết và Thực hành Dù GitHub Copilot có các bộ lọc bảo mật, các nghiên cứu thực nghiệm (Fu et al., 2025; Majdinasab et al., 2023) vẫn ghi nhận 30-35% mã AI tạo ra chứa lỗi thuộc danh mục CWE Top 25. Sự mâu thuẫn này do AI luôn ưu tiên "tính năng" (mã chạy được) hơn "bảo mật" (mã an toàn). Khác với các tiêu chuẩn kiểm soát nghiêm ngặt của NIST hay OWASP, việc quá tin tưởng vào AI đang tạo ra "điểm mù" bảo mật nếu lập trình viên bỏ qua bước kiểm duyệt.

2. Đề xuất thực tiễn: 3 nguyên tắc bảo mật cốt lõi Để an toàn, lập trình viên cần tuân thủ 3 nguyên tắc:

Quyên tắc "Zero Trust": Coi mã AI tạo ra như mã từ bên thứ ba chưa xác thực. Bắt buộc rà soát thủ công (Code Review) 100% trước khi sử dụng.

Kiểm thử tự động (Hybrid Analysis): Tích hợp các công cụ quét mã (như CodeQL, SAST/DAST) để tự động phát hiện lỗi, giúp giảm tới 50% lỗ hổng (Tài liệu 1, 5).

Viết câu lệnh định hướng bảo mật: Đưa trực tiếp ràng buộc an toàn vào prompt (VD: "*Viết hàm đăng nhập, sử dụng Bcrypt và chống SQL Injection*") để ép AI tạo mã an toàn từ gốc.

IV. KẾT LUẬN

Sự bùng nổ của các công cụ hỗ trợ mã hóa bằng AI như GitHub Copilot mang lại lợi ích to lớn về hiệu suất lập trình. Tuy nhiên, qua phân tích 5 bài báo thực nghiệm và đối chiếu với các tiêu chuẩn ngành, có thể khẳng định mã do AI tạo ra vẫn tiềm ẩn nhiều rủi ro bảo mật nghiêm trọng. AI là một trợ thủ đắc lực, nhưng không thể thay thế vai trò kiểm duyệt của con người. Để làm chủ công nghệ này an toàn, lập trình viên bắt buộc phải áp dụng tư duy "Zero Trust", tuân thủ nghiêm ngặt các tiêu chuẩn mã hóa an toàn và rà soát kỹ lưỡng mọi dòng code trước khi đưa vào ứng dụng thực tế.

TÀI LIỆU THAM KHẢO

Danh mục bài báo khoa học thực nghiệm:

1. Fu, Y., Liang, P., Tahir, A., Li, Z., Shahin, M. và Yu, J. (2025) 'Security Weaknesses of Copilot-Generated Code in GitHub Projects: An Empirical Study', *ACM Transactions on Software Engineering and Methodology*.

2. Chatterjee, S., Liu, C. L., Rowland, G. và Hogarth, T. (2024) 'The Impact of AI Tool on Engineering at ANZ Bank: An Empirical Study on GitHub Copilot within Corporate Environment', *ANZ Bank Engineering Report*.

3. Majdinasab, V., Bishop, M. J., Rasheed, S., Moradidakhel, A., Tahir, A. và Khomh, F. (2023) 'Assessing the Security of GitHub Copilot's Generated Code - A Targeted Replication Study', *arXiv preprint arXiv:2311.11177*.

4. Res, J., Smrčka, A., Homoliak, I. và Malinka, K. (2024) 'Enhancing Security of AI-Based Code Synthesis with GitHub Copilot via Cheap and Efficient Prompt-Engineering', *arXiv preprint arXiv:2403.12671*.

5. Nettur, S. B., Karpurapu, S., Nettur, U., Gajja, L. S., Myneni, S. và Dusi, A. (2025) 'The Role of GitHub Copilot on Software Development: A Perspective on Productivity, Security, Best Practices and Future Directions', *arXiv preprint arXiv:2502.13199*.

Danh mục tiêu chuẩn và báo cáo ngành:

6) GitHub (2024) GitHub Copilot Trust Center. Available at: <https://github.com/features/copilot> (Accessed: 21 March 2026).

7) MITRE (2025) CWE Top 25 Most Dangerous Software Weaknesses. Available at: <https://cwe.mitre.org/> (Accessed: 21 March 2026).

8) NIST (2024) Cybersecurity Framework (CSF) 2.0. Available at: <https://www.nist.gov/> (Accessed: 21 March 2026).

9) OWASP (2024) OWASP Top 10 for Large Language Models. Available at: <https://owasp.org/www-project-top-10-for-large-language-model-applications/> (Accessed: 21 March 2026).

10) Synopsys (2024) Open Source Security and Risk Analysis (OSSRA) Report. Available at: <https://www.synopsys.com/> (Accessed: 21 March 2026).